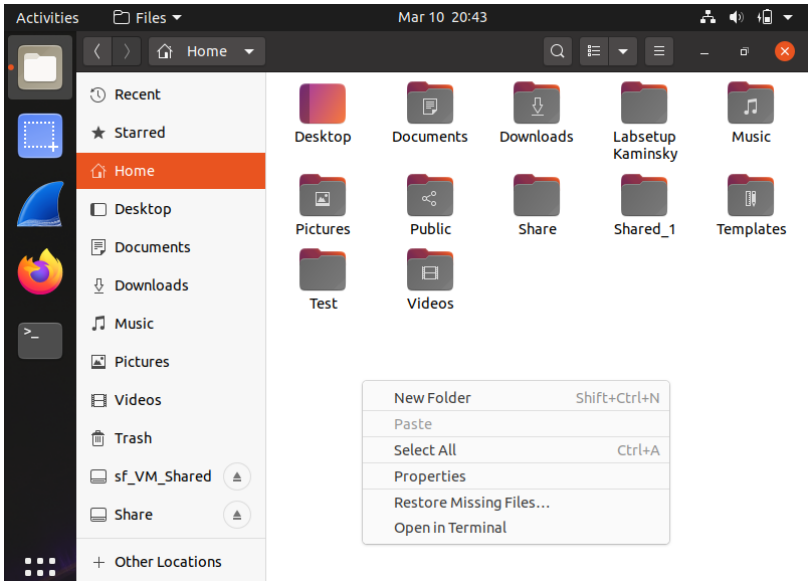
MD5 碰撞攻击实验补充说明

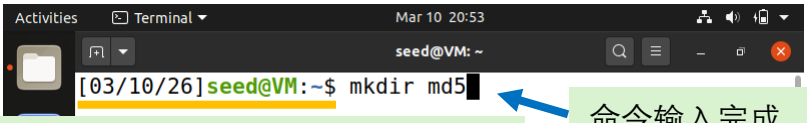
你需要按照 SEED Labs 实验手册（Homework_1_Manual_Crypto_MD5_Collision.pdf，有中英文版）填写作业模板（Homework_1_template.docx）完成作业 1。SEED Labs 实验依赖其 Linux 虚拟机进行，但很多同学没有 Linux 使用经验。本文档将对实验中的一些操作进行具体说明，方便你顺利完成作业。

1 准备工作

首先，建议你在 Home 目录下新建一个名为 md5 的文件夹，之后的操作都在这个文件夹里完成。对于这些简单任务，Seed Labs 的 Ubuntu 虚拟机提供类似 Windows 的图形界面，你可以用类似 Windows 的操作方式完成：打开 Home 文件夹后，右键点击空白处，点击 New Folder，之后给新建文件夹取名 md5（或其他你想使用的名字）。



需要说明的是，Linux 系统更多情况下需要你使用命令行窗口执行各种操作，本作业的大部分操作也是如此，需要对这种做法有基本了解。例如，上述新建文件夹的操作也可以用下述方式完成：打开 Home 文件夹后，右键点击空白处，点击 Open in Terminal 打开命令行窗口（也称终端窗口），输入 mkdir md5 并按回车执行。



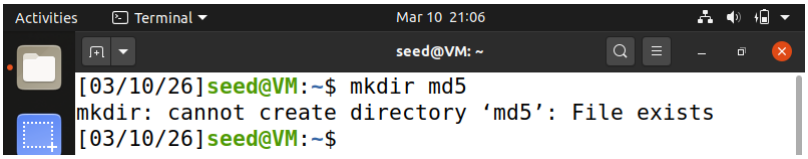
命令输入完成，按回车执行命令

黄线部分是命令提示符（与 Windows 的命令提示符同名，但所指不同），在它右侧输入命令

直接出现第二个命令行提示符，说明命令执行成功，如下图所示：

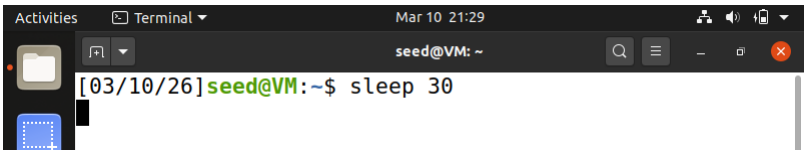
出现第二个命令提示符

如果命令没有成功执行，一般你可以在两个命令提示符之间看到提示句，说明命令未能成功执行的原因。例如，下图中显示未能创建新文件夹，原因是已有同名文件夹存在。



还有一种情况：按下回车执行命令后，有（或无）提示句出现，但迟迟不弹出第二个命令提示符，意味着执行一直没有结束。这种情况下，你可以左键点击命令行窗口内部，按 Ctrl + C，强制终止执行。之后会出现第二个命令提示符。

例如，下图中执行 sleep 30 命令，执行后没有任何提示句出现，光标在下一行空白处一直闪烁（不弹出下一个命令提示符），如果不强制结束，将会在 30 秒后自动结束并出现第二个命令提示符。



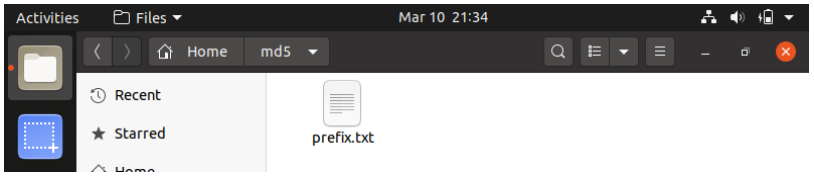
如果在这 30 秒内按 Ctrl + C（先点击窗口内部确保激活），会看到 ^C 出现，随即弹出提示符，命令被强制终止，如下图所示。

此外，在输入指令时按键盘上的上下箭头键，可以回溯之前曾执行的指令。

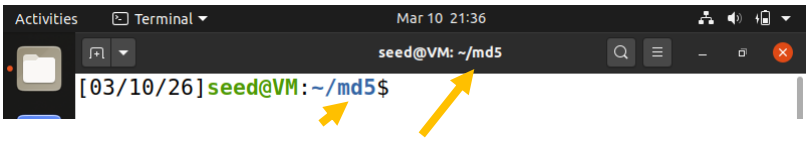
2 实验内容的具体说明

2.1 任务 1：生成两个不同但有相同 MD5 哈希值的文件

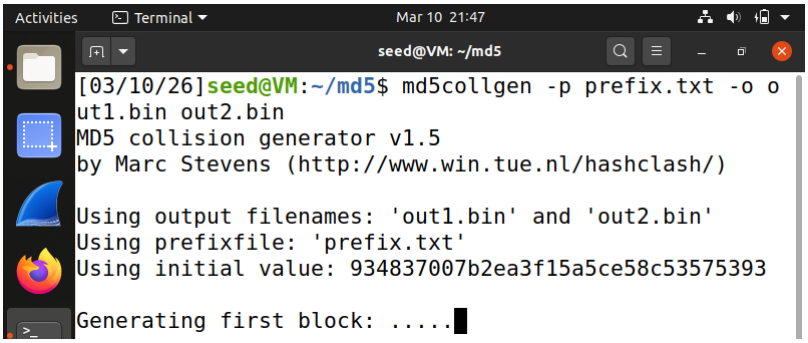
实验手册中说“以下命令为给定的前缀文件 prefix.txt 生成两个输出文件 out1.bin 和 out2.bin”，但没有说明如何执行命令。首先，prefix.txt 可以自行编写且无须在虚拟机上进行。你可以在自己的电脑操作系统里（下面以 Windows 为例）创建名为 prefix.txt 的文本文件，写入一些字符，之后通过创建虚拟机时创建的共享文件夹把它传输给虚拟机。你需要把它复制到之前创建的 md5 文件夹内（如下图所示），以进行后续操作。



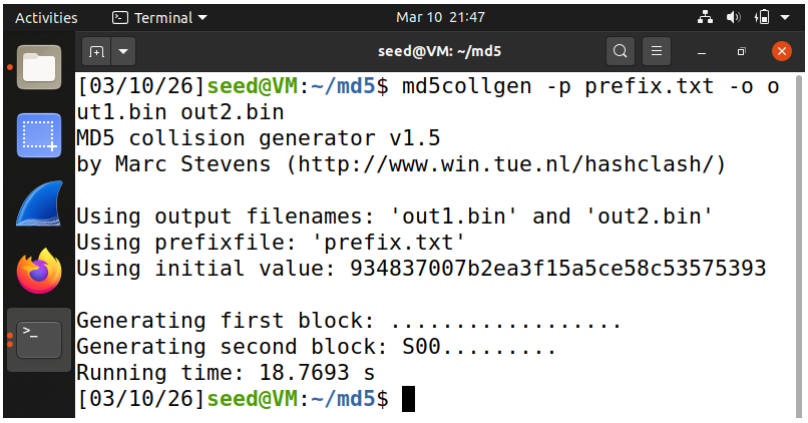
右键点击 md5 文件夹内部空白处，点击 Open in Terminal 打开命令行窗口。注意到命令提示符$前面的部分从~/变为~/md5，说明这个命令行窗口的工作目录从 Home 文件夹变为 Home 下的 md5 文件夹。后续指令默认都在这个命令行窗口中执行。若工作目录不同，输入指令时需相应调整文件路径。



现在可以执行 2.1 任务 1 了。注意：实验手册中的命令前面有$符号，这个符号不是命令的一部分。在命令行窗口中输入 md5collgen -p prefix.txt -o out1.bin out2.bin 按回车执行，如下图所示：

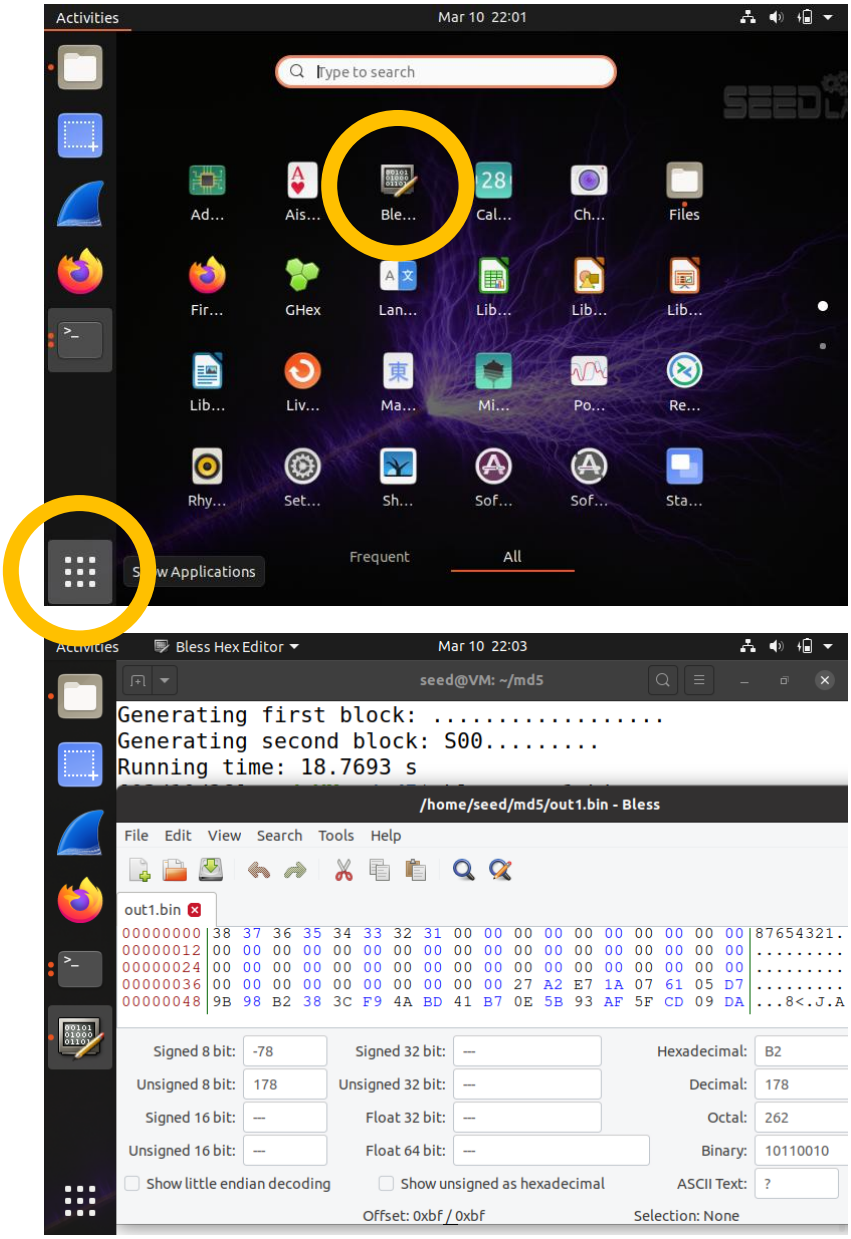


这一指令会分析 prefix.txt 文件，并且生成两个开头部分和 prefix.txt 相同，但后续内容不同的文件，分别命名为 out1.bin 和 out2.bin。具体来说，md5collgen 会在你提供的前缀后附加 128 字节的“碰撞块”，这 128 字节是两个文件唯一不同的部分。执行这一指令会花费大约几十秒（由虚拟机性能决定）。执行过程中会出现提示句，此时不要强制停止。执行完成后命令行窗口如下图所示：



无需关闭命令行窗口，之后的很多操作还会用到。回到 md5 文件夹，可以看到多出 out1.bin 和 out2.bin 两个二进制文件，它们的内容不同，但 MD5 哈希值相同。你可以在命令行窗口继续执行实验手册上的下三条指令，观察结果。

接下来实验手册提到 bless 二进制编辑器，你可以像在 Windows 操作系统上那样使用窗口化操作方式打开 bless，再打开 out1.bin。点击虚拟机窗口左下角的 Show Applications 显示所有应用，再点击 Bless，如下图所示：

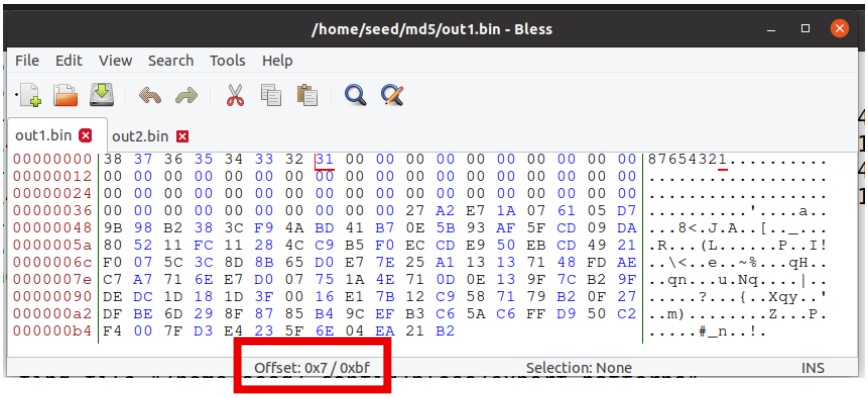


你也可以使用命令行方式进行同样操作，在之前的命令行窗口输入 bless out1.bin 指令并执行，也可以用 bless 打开 out1.bin。

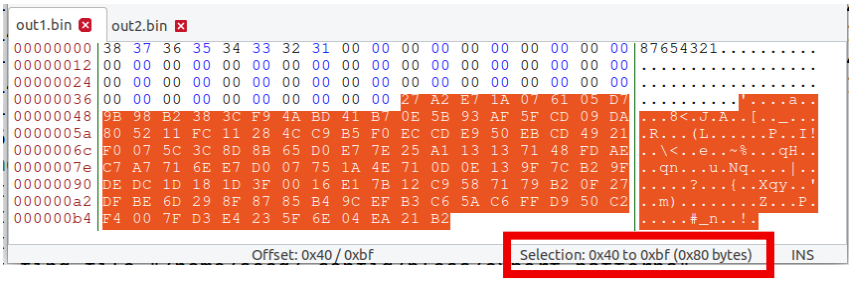
虚拟机运行 bless 可能有稳定性问题，如果你不想在虚拟机上浏览编辑二进制文件，你可以通过共享文件夹把这些文件复制到 Windows 系统上处理。在 Windows 上推荐使用 Hxd（https://mh-nexus.de/en/hxd/）编辑器。

你还可以使用其他十六进制编辑器，它们大多具有相同功能：地址（偏移量）显示、十六进制到 ASCII 码的转换、文件对比、选取给定起始地址到终止地址之间的数据、选取给定起始地址和长度的数据，等等。下面以 out1.bin 和 out2.bin 为例说明。

bless:

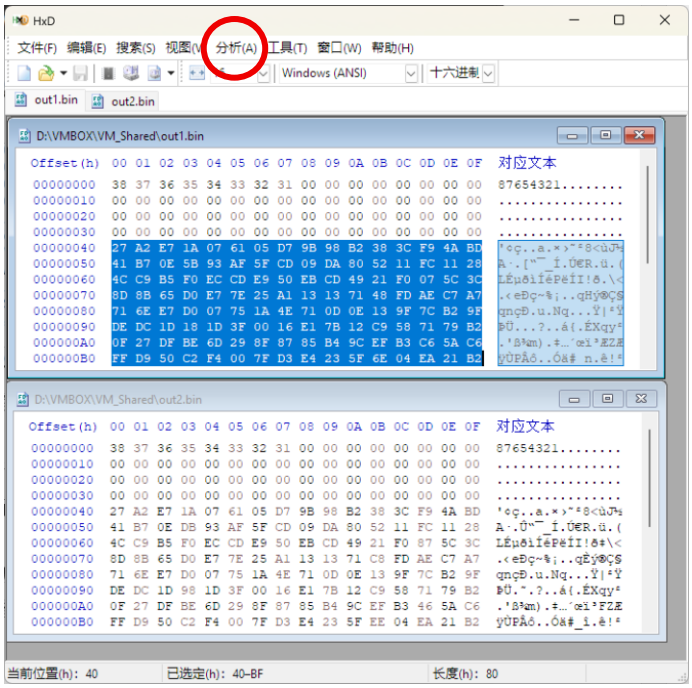


上图中，光标选择了第 8 个字节（第一行十六进制数据 31 处）。可以看到红框内的位置（偏移量），显示为 0x7 / 0xbf，表明该文件长度为 192（bf 从十六进制转换为十进制是 191，但偏移量从 0 开始，所以文件长度为 192），现在选择的是第 8 个字节（偏移量为 7）。你可以点击其他字节，会在红框中看到对应偏移量。例如，点击第一行第一列的 38 会显示 Offset: 0x0 / 0xbf。在窗口中的绿线右侧还能看到 ASCII 码对应的字符，例如，十六进制 38 对应字符为数字 8。使用这个方法，你可以在 2.3 中打开可执行文件时快速找到数组存储的位置。



Bless 同样可以选择数据并观察总长度。上图中，共选择了起始地址 0x40、结束地址 0xbf 的一共 128 个字节，也在红框里有所显示（十六进制 0x80 等于十进制 128）。

HxD 界面和功能类似，不再赘述。此外，你还可以点击分析选项（红圈处），方便找两个文件的区别。



2.2 任务 2：理解 MD5 的性质

此任务中没有需要进一步说明的内容，按实验手册说明进行即可。

2.3 任务 3：生成两个有相同 MD5 哈希的可执行文件

此任务涉及 C 语言程序的编译与运行。写源代码的部分无需在虚拟机上进行，只需要把写好的源代码文件（.c 文件）复制到 md5 工作目录里，但编译和执行需要在虚拟机上进行。虚拟机已经包含 gcc 编译器，你可以直接在 md5 文件夹的命令行窗口执行以下指令，以编译 name.c 源代码文件（文件名不同时对应替换）：

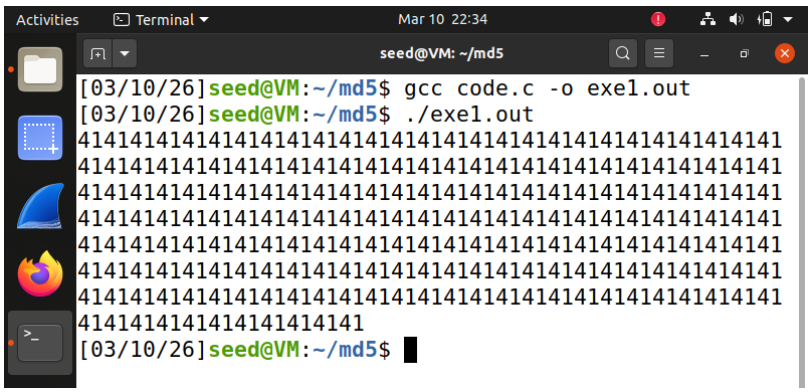
```
$ gcc name.c
```

上述指令没有指明生成的可执行文件的名字，默认将可执行文件命名为 a.out。如果你需要给可执行文件起名，可运行下述指令（编译 name.c,并将可执行文件命名为 exe1.out）：

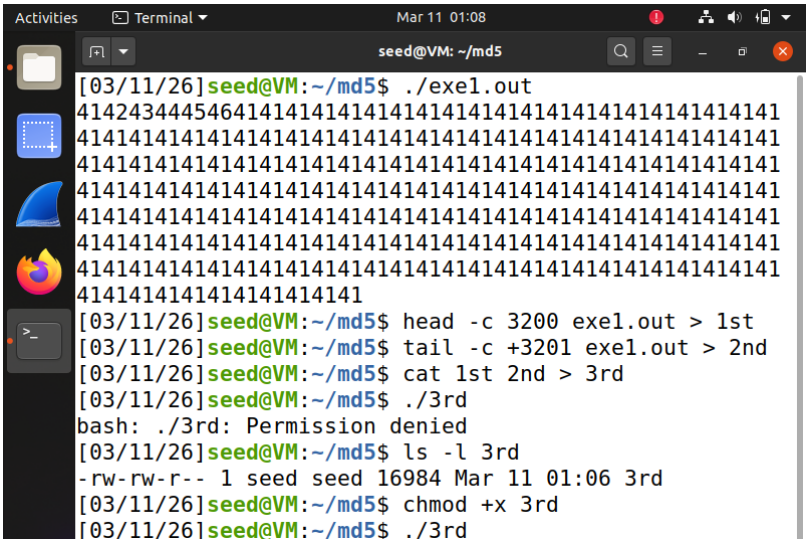
```
$ gcc name.c -o exe1.out
```

之后，你可以运行下述指令，执行刚编译得到的可执行文件（其中./指的是当前目录）：

```
$ ./exe1.out
```

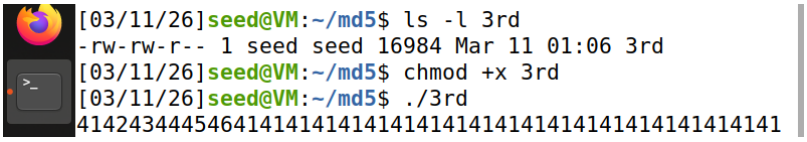


此外，在对可执行文件进行剪辑拼接后，新生成的可执行文件可能没有执行权限，如下图所示：



exe1.out 可以执行，使用 head 和 tail 两条指令分别获取 exe1.out 的前 3200 个字节（存储在 1st 文件里）和从 3201 个字节开始的所有剩余字节（存储在 2nd 文件里），再把它们拼接在一起得到 3rd 文件，理论上和原文件完全相同，但无法执行（显示 Permission denied）。这是因为新文件权限和源文

件不同，从 ls -l 3rd 指令的输出结果可以看出新文件只有部分读取和写入权限（由 r/w 指出），没有执行权限（缺少 x）。执行 chmod +x 3rd 指令赋予 3rd 文件执行权限，即可执行拼接后的 3rd 文件。



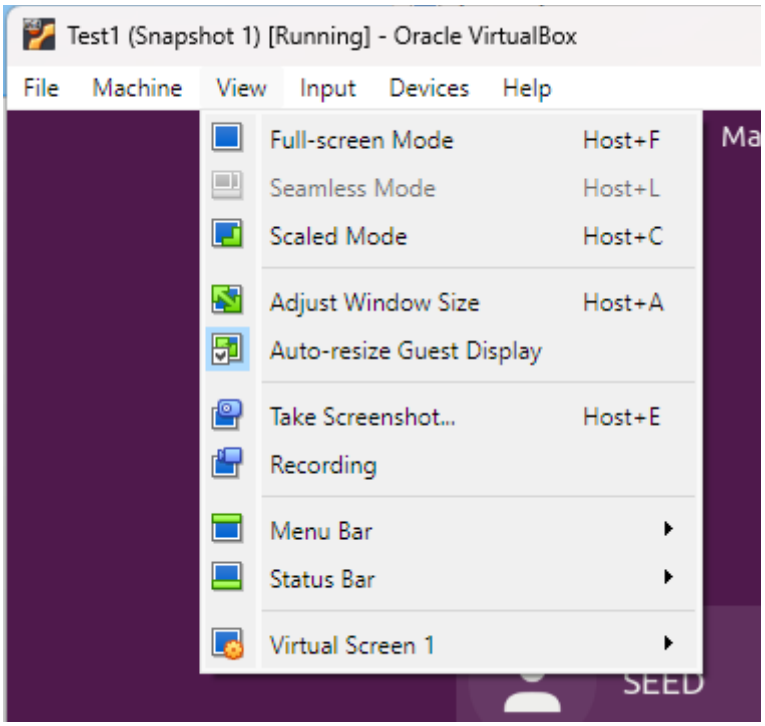
2.4 任务 4：让两个程序有不同的行为

此任务中没有需要进一步说明的内容，按实验手册说明进行即可。

3 提交作业

请在作业 1 模板（Homework 1 Template.docx）上完成，生成 pdf 文件并提交。不要提交.docx 文件。

作业中需要提交多张截图，请用虚拟机的截图功能截图（如下图所示，点击 Take Screenshot，或者按右 Ctrl + E）。请勿手机拍屏。



此外，还需要和 pdf 文件一起提交一个含有 3 个文件的压缩包。具体说明在作业模板里。